

16 · Glosario

Documentación de sistema

Versión analizada: **0.1.1+2**

Commit: **a7ebf2c**

Fecha del documento: **2026-08-27**

Documento generado desde el Markdown de **docs/system-documentation/** con **tool/build_system_documentation_pdf.py**. El Markdown es la fuente: no editar este PDF.

Contenido

1. Conceptos del producto
2. Conceptos técnicos
3. Términos de códigos y contenido
4. Estados y roles
5. Términos del proyecto y del proceso

Definiciones pensadas para que las entienda alguien sin formación técnica, con la precisión suficiente para que sirvan a quien sí la tiene.

Conceptos del producto

Hallazgo (*finding*) : Un hecho que la aplicación observó de verdad en el contenido de un código. Por ejemplo: «la dirección usa una conexión sin cifrar». No es una acusación ni una opinión: es algo comprobable mirando la carga. Cada hallazgo tiene un identificador estable, una severidad, un peso y los datos concretos que lo sustentan.

Hipótesis : Una explicación posible de por qué varios hallazgos aparecen juntos. Por ejemplo: «podría ser un intento de suplantación». Requiere investigación humana y **nunca** se convierte en certeza. Las hipótesis no suman puntos.

Evidencia : Los datos mínimos que respaldan un hallazgo: el host observado, el puerto, la extensión del archivo. También, en otro sentido, el **paquete de evidencia**: el archivo JSON que se puede compartir.

Paquete de evidencia : Archivo JSON exportable con lo que se observó de un código. Por defecto **no contiene la dirección ni el contenido**: lleva una huella digital, los identificadores de lo observado y la lista de lo que no se pudo comprobar. Sirve para pedir ayuda sin reenviar el secreto que el código llevaba dentro.

Decisión de acción : Lo que la aplicación permite hacer con el contenido. Cuatro valores: *permitir*, *confirmar*, *solo inspeccionar* y *bloquear*. Bloquear no significa «esto es malicioso»: significa «no puedo entregar esto a otra aplicación sin ambigüedad».

Severidad : La gravedad del hallazgo más grave. Tres niveles: normal, advertencia y crítico. **No** se calcula a partir del puntaje.

Puntaje : Una suma de pesos, acotada a 100. Sirve para ordenar y comparar casos. **No es una probabilidad de fraude**.

Límite (*limitation*) : Algo que la aplicación **no puede** saber sin conexión: la reputación de un sitio, quién es su dueño, qué certificado servirá. Se declara siempre, y nunca se convierte en «sin riesgo».

Carga (*payload*) : El contenido que hay dentro del código, tal como se leyó. Puede ser una dirección web, una red Wi-Fi, un contacto, una instrucción de pago o datos que no se pueden interpretar.

Superficie observable : La parte del mundo que un producto RootCause puede mirar. Aquí es «el contenido codificado en un código gráfico», no el dispositivo entero ni la red.

Sensor de apoyo a la decisión : Cómo se define este producto. No decide por la persona ni bloquea amenazas: le muestra lo que hay para que decida con información.

Conceptos técnicos

AES-256-GCM : El método de cifrado que protege lo guardado. Además de ocultar el contenido, detecta si alguien lo modificó: al descifrar, un archivo alterado se rechaza en lugar de devolver datos falsos.

Base de datos embebida : Una base de datos que vive dentro de la aplicación, en un archivo del propio teléfono. No hay servidor, ni contraseña, ni conexión.

Checksum · SHA-256 : Una «huella digital» de un archivo o un texto: una cadena de 64 caracteres que cambia por completo si cambia un solo byte. Sirve para comprobar que algo no se modificó. **No** dice quién lo creó.

Cifrado autenticado : Cifrado que, además de ocultar, garantiza que el contenido no se alteró.

Compilación condicional : Técnica para que un mismo código use una implementación distinta según la plataforma. Aquí decide si la base de datos es un archivo o el almacén del navegador.

Función pura : Una función que, con las mismas entradas, devuelve siempre lo mismo, y no toca nada fuera de sí misma. El motor de reglas lo es, y por eso puede probarse sin teléfono.

Idempotente : Que se puede repetir sin cambiar el resultado. Las migraciones lo son: ejecutarlas dos veces equivale a ejecutarlas una.

Lockfile : Archivo que fija la versión exacta de cada dependencia, incluidas las indirectas. Garantiza que dos compilaciones del mismo código usen lo mismo.

Sobre cifrado (*envelope*) : El paquete que envuelve un dato cifrado: versión del formato, algoritmo, identificador de la llave, instante, y el contenido cifrado con su marca de integridad.

Transacción : Un conjunto de cambios que ocurren todos o ninguno. Si algo falla a mitad, todo vuelve al estado anterior.

SBOM : *Software Bill of Materials*: la lista de todos los componentes de terceros que usa el programa, con su versión. Sirve para saber si un aviso de seguridad afecta al producto.

Isolate : En Dart, un hilo de ejecución con memoria propia. Aquí se usa para generar CSV y Excel sin congelar la pantalla.

Términos de códigos y contenido

QR · Código de barras · Simbología : Un QR es un código de dos dimensiones. Un código de barras clásico es de una. *Simbología* es el nombre del formato concreto: QR Code, Data Matrix, Aztec, PDF417, EAN-13, Code 128...

Punycode : Forma de escribir dominios con caracteres no latinos usando solo letras inglesas; empiezan por xn- . Es legítimo, pero permite crear nombres que **se ven** casi idénticos a los de otra marca.

Alfabetos mezclados (*mixed script*) : Un dominio que combina letras de alfabetos distintos —latino, cirílico, griego— para imitar visualmente otro nombre. La «■» cirílica y la «a» latina se ven iguales.

Userinfo : La parte de una dirección que va antes de @. En `https://banco.example@evil.example`, el destino real es `evil.example`, aunque a primera vista parezca lo contrario.

Acortador : Un servicio que convierte una dirección larga en una corta. Oculta el destino final hasta que se abre.

Redirección anidada : Una dirección que lleva otra dentro, en uno de sus parámetros. La visible puede ser conocida y la escondida, no.

Autoridad : La parte de una dirección que identifica el destino: usuario, host y puerto.

URI · URL · Esquema : Una URI identifica un recurso; una URL es una URI que además dice cómo llegar. El *esquema* es lo que va antes de los dos puntos: `https`, `mailto`, `wifi`, `otpauth`.

OTP : *One-Time Password*. Los códigos de seis dígitos que cambian cada 30 segundos. Un QR `otpauth`: contiene la **semilla** que los genera: quien la tenga puede generarlos todos.

vCard · MeCard : Formatos de tarjeta de contacto dentro de un código.

GS1 · GTIN · SSCC : Estándares de identificación de productos y logística. GTIN es el número que identifica un producto; SSCC, una unidad de envío.

EMVCo · EPC/SEPA · Swiss QR : Formatos de QR de pago: interoperable internacional, europeo de transferencia y suizo de factura.

AAMVA : Formato de los datos de una licencia de conducir estadounidense, normalmente en un PDF417.

Carga binaria : Contenido que no es texto y no se puede interpretar. La aplicación lo declara opaco: opacidad no equivale a malicia.

Estados y roles

Fases de la cámara : Preparando (arrancando), Inspección activa (analizando), Código leído (acaba de capturar), Inspección en pausa (detenida por la persona) y Sensor no disponible (no pudo arrancar).

Modo temporal : Arranque de emergencia que usa una base en memoria y una llave que no se guarda. Nada sobrevive al cierre. Aparece cuando el almacenamiento normal falla.

Modo privado : Preferencia que impide guardar cualquier lectura mientras está activa.

Registro aislado : Un registro que no se pudo descifrar. Se aparta para que no impida leer los demás, y **nunca** se borra solo.

Rotación de llave : Cambiar la llave de cifrado y volver a cifrar todo con la nueva, en una sola operación que o se completa entera o no ocurre.

Contenido sensible : Contraseñas Wi-Fi, semillas OTP, datos de pago, documentos de identidad y direcciones con secretos. Se muestran pero **no se guardan**.

Términos del proyecto y del proceso

RootCause : La familia de productos a la que pertenece esta aplicación, organizada por superficie observable, no por tipo de amenaza.

Universal Code Scanner : El proyecto del que procede el subsistema de lectura, interpretación, cifrado e inventario. La procedencia se conserva documentada.

Bootstrap : Aquí, `tool/bootstrap.py`: el script que genera las carpetas de Android, iOS y web, y les aplica los ajustes necesarios. También, el arranque de la aplicación.

Gate : Una comprobación que debe pasar antes de continuar. Si falla, se detiene la publicación.

CI : *Integración continua*. Comprobaciones automáticas que se ejecutan en servidores de GitHub cada vez que cambia el código.

Fixture : Un caso de prueba con datos preparados y un resultado esperado.

Deriva de versión (*drift*) : Que la versión mostrada, la construida y la documentada dejen de coincidir. El repositorio tiene una comprobación específica para impedirlo.

Telemetría cero : Que la aplicación no envía absolutamente ninguna información sobre su uso.

Redacción (*redaction*) : Quitar deliberadamente información de un documento antes de compartirlo. Aquí, la carga y la dirección efectiva se omiten del paquete de evidencia.

Entrada no confiable : Cualquier dato que venga de fuera y pueda estar manipulado. Los respaldos importados se tratan así: todo campo calculado se vuelve a calcular.